12.4.4 Post-compromise security

Although forward secrecy protects old communications if a device is later compromised, it says nothing about the security of future communications. There have been many stories in the press in recent years of IoT devices being compromised, so being able to recover security after a compromise is a useful security goal, known as *post-compromise security*.

> **DEFINITION** ***Post-compromise security*** (or ***future secrecy***) is achieved if a device can ensure security of future communications after a device has been compromised. It should not be confused with *forward secrecy* which protects confidentiality of past communications.

Post-compromise security assumes that the compromise is not permanent, and in most cases it's not possible to retain security in the presence of a persistent compromise. But in some cases it may be possible to re-establish security once the compromise has ended. For example, a *path traversal vulnerability* might allow a remote attacker to view the contents of files on a device, but not modify them. Once the vulnerability is found and patched, the attacker's access is removed.

> **DEFINITION** A ***path traversal vulnerability*** occurs when a web server allows an attacker to access files that were not intended to be made available by manipulating the URL path in requests. For example, if the web server publishes data under a /data folder, an